SECURITY OPERATIONS / HOME LAB

Análise simulada de incidente

Falhas de autenticação seguidas de login bem-sucedido

SIMULAÇÃO — Nenhum host, usuário, pacote de rede ou conta real foi monitorado. O IP 203.0.113.66 pertence a uma faixa reservada para documentação e não identifica uma origem real.

1. Resumo executivo

O cenário **compromised**, seed **2026**, gerou 16 eventos sintéticos. Cinco falhas de login para **admin** ocorreram do mesmo IP entre 12:30 e 12:34 UTC; um sucesso para a mesma conta e origem veio às 12:35 UTC. O detector produziu um alerta **medium** de falhas repetidas e um alerta **high** pela correlação com o sucesso. O alerta high foi registrado como **investigating**; o medium permanece **open**.

Conclusão do exercício: os eventos satisfazem as regras implementadas. Isso não prova comprometimento real; é necessário validar fontes originais e contexto antes de classificar um incidente.

2. Escopo e reprodução

Item	Valor	O que representa
Cenário / seed	compromised / 2026	Entrada reproduzível do simulador.
Eventos	16	10 eventos de contexto e 6 eventos da sequência de teste.
Host	auth-server-01	Nome fictício incluído pelo gerador.
Run ID	ac958c2bb9d5494b921fd16a81719abc	Execução registrada no SQLite local.
Resposta	Nenhuma	Nenhum bloqueio ou ação automática foi executado.

Reprodução sem alterar o banco principal:

```
./.venv/bin/python -m soc_lab.simulator --scenario compromised --seed 2026 --output /tmp/soc-lab-compromised-2026.jsonl
./.venv/bin/python -m soc_lab.cli --input /tmp/soc-lab-compromised-2026.jsonl --db /tmp/soc-lab-analysis.sqlite
```

3. Linha do tempo observada

Horário UTC	Evento sintético	Interpretação
12:30	Falha para admin de 203.0.113.66	Primeira falha.
12:31–12:33	Mais três falhas para a mesma conta e origem	Contagem sobe para quatro.
12:34	Quinta falha para a mesma conta e origem	A regra de falhas repetidas atinge o limiar 5/10 min.
12:35	Sucesso para admin do mesmo IP	A regra de correlação encontra sucesso em até 5 min.

4. Significado dos campos

Campo	Exemplo	Significado / limite
timestamp	12:30–12:35 UTC	Tempo fictício do evento; UTC facilita ordenar fontes.
event_type	authentication	Classifica o registro; não é captura de pacote.
source_ip	203.0.113.66	IP sintético. Não identifica uma pessoa nem uma rede real.
username	admin	Conta-alvo fictícia; não revela quem tentou autenticar.
outcome	failure / success	Resultado produzido pelo simulador, não confirmado por um IdP real.
hostname	auth-server-01	Nome de host fictício atribuído aos eventos.
event_id	evt-0011…evt-0016	Identificador sequencial para localizar registros no conjunto.
scenario	compromised	Rótulo do teste; não é veredito de incidente.

5. Regras acionadas

multiple_failed_logins — medium. Agrupa falhas por IP e verifica se há pelo menos cinco em uma janela móvel de dez minutos. Esta regra não precisa saber o usuário; por isso não é a regra que afirma que admin autenticou com sucesso.

successful_login_after_failures — high. Correlaciona pelo par IP + usuário. Encontrou cinco falhas para admin entre 12:30 e 12:34 e um sucesso às 12:35. A diferença de um minuto está dentro da janela configurada de cinco minutos, então a severidade foi elevada.

São dois alertas sobre os mesmos eventos, não duas ocorrências independentes. Um SIEM mais completo poderia agrupar ambos em um único caso para reduzir duplicidade.

6. Raciocínio de triagem

Categoria	Análise
Observação	Cinco falhas e um sucesso subsequente compartilham o mesmo IP e usuário no conjunto gerado.
Hipótese	Se fossem logs reais, a sequência justificaria investigar uso de credenciais após tentativas repetidas.
Não demonstrado	Não há evidência de senha descoberta, acesso real, identidade do operador, MFA ou atividade pós-login.
Alternativas benignas	Erro de digitação antes do sucesso, teste autorizado, suporte ou endereço intermediário compartilhado.
Confiança	Alta de que a regra corresponde aos eventos sintéticos; nenhuma conclusão sobre um ambiente real.

7. Decisão registrada e próximos passos

O alerta high, ID **22d19b8ead764333bb959ce0bde6812f**, está **investigating**. A nota persistida marca explicitamente a simulação e recomenda verificar logs originais antes de concluir comprometimento. O alerta medium, ID **c53808f573ce4dec8578f0303dc0605f**, permanece **open**.

- Confirmar IP, host, usuário e método nos logs originais do sistema ou provedor de identidade.
- Verificar se o sucesso e o dispositivo/sessão eram esperados e revisar atividade posterior.
- Consultar MFA, origem e histórico da conta para comparação com o comportamento normal.

• Se evidências reais confirmarem risco, seguir o procedimento autorizado da organização para proteger a conta e revogar sessões.

8. Limitações e conclusão

O laboratório analisou somente JSONL sintético. Não leu logs do Windows/Linux, não observou tráfego, não analisou TCP/UDP e não executou resposta automática. O estado **investigating** é parte do exercício. Nunca bloquear o IP de documentação com base neste resultado; em caso real, validar evidências originais e seguir o processo autorizado.